Zoho Model Context Protocol (MCP) Data Governance & Contractor Offboarding Protocol

Executive Summary

When integrating external Model Context Protocol (MCP) tools—such as Zoho Books—with third-party AI interfaces like Anthropic's Claude, organizations face a critical data boundary challenge. Once data is transmitted via an API response to an external personal account (e.g., a `@gmail.com`-linked Claude account), it resides outside the direct administrative control of the enterprise.

This document outlines the technical realities of historical data retention and establishes both a remediation workflow for existing exposures and a proactive architectural framework for future deployments.

Part 1: Remediation for Historical Data Exposure

Because neither Zoho nor enterprise administrators hold administrative control over a consultant's personal $@gmail.com$ Claude account, remote technical wiping of historical chat logs is impossible. Resolving an active exposure requires a structured, compliance-driven offboarding process:

- **Live Screen-Share Verification:** As a condition of final invoice clearance and offboarding, require the consultant to participate in a brief live screen-share session. The consultant must filter their Claude chat history and Claude Projects for keywords such as "Zoho", "Necrop", or specific financial terms, and manually delete those threads. Deletion removes the thread from the user interface immediately and initiates a backend purge within Anthropic's retention window (typically 30 days).
- **Signed Data Destruction Attestation:** Require the consultant to execute a formal legal declaration confirming that all chat threads, downloaded export artifacts (CSV/JSON), and local MCP configuration tokens relating to company data have been permanently destroyed.

Part 2: Proactive Architecture for Future Deployments

To ensure that contractor offboarding results in the immediate, absolute revocation and deletion of all historical AI chat logs and retrieved enterprise data, organizations must

eliminate direct personal account integrations. Implement one of the following five architectural controls before granting future MCP access:

Option A: Corporate-Issued Identity for Managed AI Accounts (Native Enforcement)

Prohibit the use of personal $@gmail.com$ accounts for enterprise work.

- **Implementation:** Issue the consultant a managed corporate email address (e.g., `consultant@company.com`) and provision a seat within a Claude for Team or Enterprise organization utilizing Single Sign-On (SSO).
- **Lifecycle Management:** Upon offboarding, deactivating the corporate email and revoking the SSO session locks the user out of the organization's Claude workspace instantly, securing all historical chat logs and retrieved data.

Option B: Self-Hosted Enterprise AI Gateway (Centralized Storage)

Instead of allowing consultants to connect third-party MCP clients locally, deploy a centralized, company-hosted AI portal (such as LibreChat, Open WebUI, or TypingMind Enterprise).

- **Implementation:** Integrate your Anthropic API keys and the Zoho Books MCP server directly into the internal gateway.
- **Lifecycle Management:** Users authenticate into the company-controlled portal. All conversation histories and retrieved ledger data reside in the corporate database rather than personal accounts. Deleting the user profile instantaneously terminates access to historical records.

Option D: Virtual Desktop & Browser Isolation (Ephemeral Workspaces)

Restrict access to AI tools and financial systems to secure, company-managed virtual environments.

- **Implementation:** Require consultants to access both Claude and Zoho exclusively within provisioning-controlled virtual desktops or secure enterprise browsers (such as AWS WorkSpaces, Azure Virtual Desktop, or Island).
- **Lifecycle Management:** Upon contract conclusion, destroying the virtual instance purges all local cache, downloaded files, and browser state entirely.

Option E: Custom-Built Internal Web Application with Integrated LLM & MCP Client

Build a bespoke web application (e.g., using React/Next.js for the frontend and Python FastAPI or Node.js for the backend) that completely replaces the Claude consumer UI.

- **Implementation:**
    - **Proprietary Interface:** Users interact with a clean, branded chat interface hosted entirely on your infrastructure.
    - **Direct Server-Side MCP Execution:** The backend application directly communicates with the Anthropic Claude API for reasoning while programmatically executing Zoho MCP tools server-side.
- **Lifecycle Management:** All chat logs, tool queries, and retrieved Zoho Books data are written exclusively to your enterprise database (e.g., PostgreSQL). When a contractor's access is revoked, their conversation history and retrieved financial ledgers remain securely housed within your environment, entirely divorced from any personal consumer accounts.